

EduNex Automated Testing And Security Report

Automated testing and security summary

Generated: 2026-09-02 16:39 IST

Scope

- Backend: `http://localhost:3000`
- Frontend: `http://localhost:5173`
- Repository: `Edu-nex_Final`
- Mode tested: local development with demo OTP and simulated payment config

This report does not include real `.env` secret values.

Executive Summary

Overall local app status is good for development testing. The backend is running, MongoDB is connected, public catalog APIs respond correctly, frontend production build succeeds, demo OTP works, and local payment callback redirects to the frontend instead of the dead `api.edunex.live` domain.

The app is not production-ready yet because the backend dependency audit still has vulnerable packages, HTTP security headers are missing, token storage still uses browser storage, rate limits are in-memory, and the frontend still has fallback references to the old `api.pendulumblog.online` backend.

Automated Test Results

Check	Command	Result
Backend smoke test	<code>npm run smoke:api in edunex-b</code>	PASS
Frontend production build	<code>npm run build in edunex-f</code>	PASS
Backend dependency audit	<code>npm audit --audit-level=low in edunex-b</code>	FAIL
Frontend dependency audit	<code>npm audit --audit-level=low in edunex-f</code>	PASS
Frontend login k6 smoke	<code>PROFILE=smoke TARGET_URL=http://localhost:5173 npm run k6:login:smoke</code>	PASS
Backend public API k6 smoke	<code>STEPS=10, 50 ENDPOINTS=health-db, categories, courses, checkout-summary REPORT_SCOPE=local-automated-20260902 npm run k6:api:common</code>	PASS

Backend Smoke Test

Passed:

- `GET /api/health`
- `GET /api/health/db`
- `GET /api/bunny/videos` rejects anonymous access
- `POST /api/admin/login` rejects bad password
- `GET /api/image-proxy` blocks private localhost target

- GET /api/courses returned 7 courses
- GET /api/categories returned 5 categories

Skipped because smoke credentials were not configured:

- User login and /api/auth/me
- User sessions
- User subscription/progress APIs
- Authenticated payment status
- Authenticated course video/progress writes
- Authenticated admin routes
- Bunny thumbnail route requiring a Bunny GUID

Required env keys for full authenticated smoke coverage:

- SMOKE_LOGIN_ID
- SMOKE_PASSWORD
- SMOKE_USER_ID
- SMOKE_COURSE_ID
- SMOKE_VIDEO_ID
- SMOKE_LESSON_ID
- SMOKE_ADMIN_PASSWORD
- SMOKE_BUNNY_GUID

k6 Backend Results

All tested public API endpoints passed with 0.00% failed request rate and 100.00% check pass rate.

Endpoint	Requests	Avg	p95	p99	Result
GET /api/health/db	10	38.77 ms	76.70 ms	104.94 ms	PASS
GET /api/health/db	50	40.01 ms	68.59 ms	192.56 ms	PASS
GET /api/categories	10	1.54 ms	2.24 ms	2.39 ms	PASS
GET /api/categories	50	8.77 ms	30.74 ms	135.11 ms	PASS
GET /api/courses	10	14.90 ms	75.19 ms	122.91 ms	PASS
GET /api/courses	50	2.28 ms	4.18 ms	4.52 ms	PASS
GET /api/courses/checkout-summary	10	4.88 ms	20.35 ms	32.36 ms	PASS
GET /api/courses/checkout-summary	50	2.07 ms	3.97 ms	4.97 ms	PASS

Generated k6 index:

- edunex-b/reports/k6/common-api-local-automated-20260902-index.md

k6 Frontend Results

Frontend login page smoke test passed.

Target	Requests	Failed	Checks	Avg	p95	p99	Result
http://localhost:5173/login	10	0.00%	100.00%	3.64 ms	4.94 ms	5.22 ms	PASS

Generated k6 report:

- `edunex-f/reports/k6/login-page-smoke.md`

Security Surface Checks

Passed:

- `.env` and `.env.local` are ignored by git.
- Only `.env.example` files are tracked.
- `GET /api/admin/users` returns 401 without admin token.
- `GET /api/bunny/videos` returns 401 without admin token.
- `GET /api/image-proxy?url=http://127.0.0.1:1/image.png` returns 400.
- `GET /api/payment/callback` without transaction now redirects to `http://localhost:5173/courses.html`.
- Demo OTP send returns `provider: "demo"` and exposes the configured demo OTP only in development.
- Production startup guard blocks demo/temp/mock OTP modes.

Needs work:

- Backend responses expose `X-Powered-By: Express`.
- Backend does not currently send standard security headers such as `Content-Security-Policy`, `Strict-Transport-Security`, `X-Content-Type-Options`, `X-Frame-Options` or CSP `frame-ancestors`, and `Referrer-Policy`.
- Frontend fallback API config still references old `api.pendulumblog.online` in `edunex-f/vite.config.js`.
- Netlify redirects still point `/api/*` to old `https://api.pendulumblog.online/api/:splat` in `edunex-f/_redirects`.
- Access and refresh tokens are still stored in `localStorage` or `sessionStorage`.
- Auth and OTP rate limiting is in memory, so it resets on restart and will not coordinate across multiple backend instances.

Dependency Audit

Frontend:

- `npm audit --audit-level=low` found 0 vulnerabilities.

Backend:

- `npm audit --audit-level=low` found 13 vulnerabilities:
- 1 low
- 9 moderate
- 2 high
- 1 critical

Important backend vulnerable chains:

- `websocket-driver <=0.7.4`, critical, through `firebase-admin`.
- `protobufjs <=7.6.4`, high, through Google/Firebase packages.
- `form-data <2.5.6`, high, through Google storage request packages.
- `mongoose 9.0.0 - 9.7.1`, moderate.
- `uuid <11.1.1`, moderate, through Google/Firebase packages.
- `body-parser 2.0.0 - 2.2.2`, request size enforcement DoS advisory.

Dry-run fix result:

- Normal `npm audit fix --dry-run` can update several transitive dependencies, including `body-parser`, `mongoose`, `protobufjs`, `form-data`, `websocket-driver`, and `@google-cloud/storage`.
- Full cleanup may require testing a breaking `firebase-admin` major upgrade to `14.x`.

Main Findings

High: Backend Dependency Vulnerabilities

The backend audit is the largest concrete blocker. Fixing this should be first before production deployment.

Recommended action:

- Run `npm audit fix` in a branch.
- Run backend smoke, k6 public API checks, admin checks, and payment checks again.
- Then separately test `firebase-admin@14.x` if any vulnerabilities remain.

High: Frontend Can Still Fall Back To Old Backend

Two files still reference `api.pendulumblog.online`:

- `edunex-f/vite.config.js`
- `edunex-f/_redirects`

This can break local/dev/prod if env variables are missing or if Netlify uses `_redirects`.

Recommended action:

- Change the Vite fallback to the new backend URL or fail clearly when `VITE_API_PROXY_TARGET` is missing.
- Update `_redirects` to point to the real new backend deployment.

Medium: Missing HTTP Security Headers

The backend does not send common security headers and still exposes Express.

Recommended action:

- Add `helmet`.
- Disable `X-Powered-By`.
- Configure CSP carefully so admin/frontend assets still load.

Medium: Token Storage In Browser Storage

The frontend stores bearer tokens in browser storage. Any XSS would expose user sessions.

Recommended action:

- Move refresh tokens to `HttpOnly, Secure, SameSite` cookies.
- Keep access tokens short-lived.
- Add refresh token rotation and reuse detection.

Medium: In-Memory Rate Limits

Current rate limits help on one local process, but are weak for production scaling.

Recommended action:

- Use Redis-backed rate limiting for login, OTP, admin login, AI/chat, contact, and payment-initiation routes.

Recommended Next Fix Order

- 1 Fix frontend old backend references in `vite.config.js` and `_redirects`.
- 2 Apply safe backend dependency updates with `npm audit fix`, then retest.
- 3 Add backend security headers with `helmet` and disable X-Powered-By.
- 4 Add full authenticated smoke credentials for user/admin/course/payment tests.
- 5 Move auth refresh token handling toward secure cookies.
- 6 Replace in-memory rate limits with Redis-backed limits before multi-instance deployment.

Current Verdict

Good for local development and demo testing.

Not yet ready for production security sign-off.